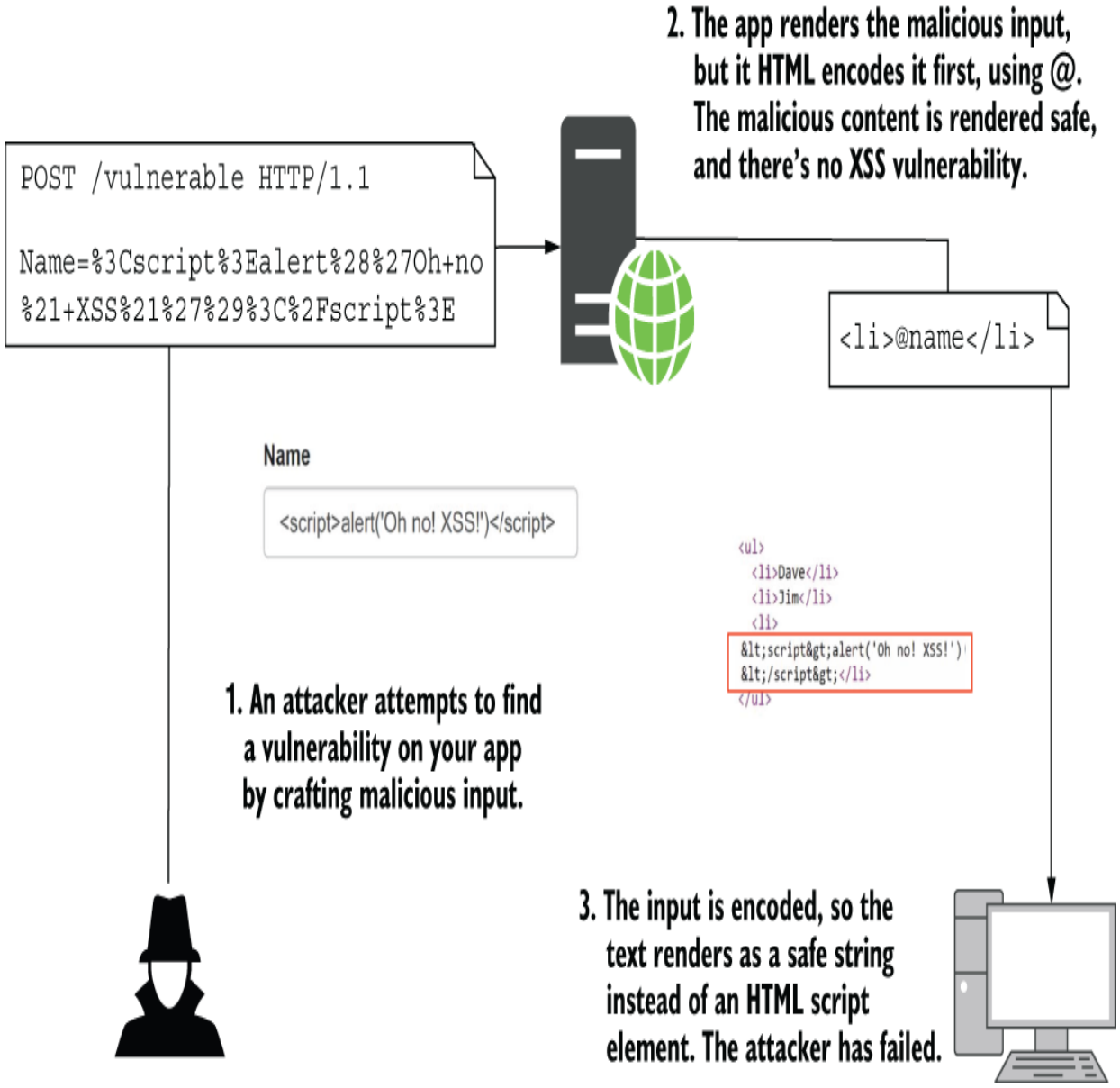


Figure 29.2 Protecting against XSS attacks by HTML-encoding user input using @ in Razor templates. The `<script>` tag is encoded so that it is no longer rendered as HTML and can't be used to compromise your app.

This example demonstrates using HTML encoding to prevent elements being directly added to the HTML Document Object Model (DOM), but it's not the only case you have to think about. If you're passing untrusted data to